

Ubuntu Innovations (Pty) Ltd

IT Security Documentation

Week 3 – Tasks 4 & 5 | Capstone Project

Prepared by: Junior IT Support Specialist | June 2025

Task 4: Incident Response Plan

This Incident Response Plan (IRP) defines the structured procedures Ubuntu Innovations (Pty) Ltd will follow when a cybersecurity incident is detected. The plan ensures rapid containment, minimal business disruption, and continuous improvement through post-incident review.

4.1 Purpose and Scope

The purpose of this IRP is to provide a clear, repeatable framework for identifying, managing, and recovering from security incidents. It applies to all 25 employees, IT systems, cloud services, and network infrastructure operated by Ubuntu Innovations.

4.2 Incident Classification

Incidents are categorised by severity to ensure appropriate escalation and resource allocation:

Severity	Description	Examples	Response Time
Critical	Immediate threat to operations or data	Ransomware, data breach, system compromise	Within 1 hour
High	Significant threat requiring urgent attention	Phishing attack, malware detection, unauthorised access	Within 4 hours
Medium	Moderate risk with limited immediate impact	Policy violation, suspicious activity, failed login attempts	Within 24 hours
Low	Minor issues with minimal risk	Spam emails, minor misconfigurations	Within 72 hours

4.3 Roles and Responsibilities

IT Administrator	Leads technical investigation, implements containment and eradication measures, maintains forensic evidence.
Department Heads	Report suspected incidents, ensure staff cooperate with the IRP process, and communicate updates to their teams.

Executive Management	Authorise major response actions (e.g. system shutdowns), manage external communications, and liaise with legal counsel if required.
All Employees	Report suspicious activity immediately to IT and do not attempt self-remediation. Follow IT instructions during an active incident.

4.4 The Six-Phase Incident Response Process

Phase 1: Detection

Detection involves identifying that a security incident has occurred or is in progress. Ubuntu Innovations will use the following detection mechanisms:

- Automated alerts from ClamAV and Malwarebytes endpoint protection.
- UFW firewall logs reviewed weekly by the IT Administrator.
- Google Workspace security alerts (suspicious login, data export).
- Employee reports of unusual system behaviour or suspicious emails.
- Netdata / Zabbix server monitoring alerts for anomalous traffic spikes.

Phase 2: Reporting

Once a potential incident is detected, it must be formally reported and logged without delay.

- All employees must report suspected incidents to the IT Administrator immediately via email or in-person.
- The IT Administrator logs the incident in the Incident Register, recording: date/time, reporter name, affected systems, initial description, and severity classification.
- Critical and High incidents must also be escalated verbally to Executive Management within one hour.
- An Incident Ticket is opened in the helpdesk system to track all actions taken.

Phase 3: Containment

Containment limits the spread and damage of the incident. Ubuntu Innovations follows a two-stage containment approach:

- Short-term containment: Isolate the affected device(s) from the network by disabling the network interface or unplugging the Ethernet cable. Revoke active user sessions if an account is compromised.
- Long-term containment: Apply temporary patches or configuration changes to prevent recurrence while a permanent fix is developed. Preserve forensic evidence (do not wipe or reboot affected machines before imaging).
- The IT Administrator documents all containment actions with timestamps in the Incident Register.

Phase 4: Eradication

Eradication removes the root cause of the incident from the environment.

- Identify and remove all malicious files, malware, or unauthorised accounts using antivirus tools and manual inspection.
- Patch the vulnerability or misconfiguration that allowed the incident to occur.
- Reset all compromised user credentials and enforce immediate password changes via Google Workspace admin.
- Confirm eradication by running a full system scan with Malwarebytes and ClamAV.
- Verify no persistence mechanisms (cron jobs, startup scripts, backdoors) remain on affected systems.

Phase 5: Recovery

Recovery restores affected systems to normal operations securely.

- Restore data from the most recent clean backup (daily incremental or weekly full via NAS / cloud).
- Reconnect systems to the network only after full eradication is confirmed.
- Monitor restored systems closely for 48–72 hours using Netdata for unusual activity.
- Communicate to staff when systems are restored and safe to use.
- Update DNS, DHCP, and OpenLDAP configurations as needed if systems were re-provisioned.

Phase 6: Lessons Learned

Within five business days of incident closure, a post-incident review meeting will be held with all relevant parties. The review will cover:

- Root cause analysis – what allowed the incident to occur?
- Effectiveness of the response – what worked well and what did not?
- Gaps identified in tools, policies, or staff awareness.
- Action items assigned with owners and due dates.
- Updated Incident Register and final Incident Report shared with Executive Management.

4.5 Phase Summary Table

Phase	Key Actions	Responsible Party	Target Timeline
1. Detection	Monitor alerts, review logs, identify anomalous behaviour	IT Administrator	Ongoing / Real-time
2. Reporting	Log incident, notify IT Admin, escalate to management if Critical/High	All staff / IT Admin	Immediately on detection
3. Containment	Isolate affected systems, preserve evidence, apply temporary fixes	IT Administrator	Within 1–4 hours
4. Eradication	Remove malware/root cause, patch vulnerability, reset credentials	IT Administrator	Within 24–48 hours
5. Recovery	Restore from backup, reconnect systems, monitor closely	IT Administrator	Within 24–72 hours
6. Lessons Learned	Post-incident review, root cause analysis, update policies	IT Admin + Management	Within 5 business days

4.6 Incident Response Contact List

IT Administrator	Primary technical responder – first point of contact for all incidents.
Executive Management	Authorise major decisions; manage legal/PR communications.
Google Workspace Admin	Account recovery, access revocation, security log review.
Malwarebytes Support	Vendor escalation for advanced malware analysis.
South African Cybercrime	0800 023 123 – report cybercrime incidents affecting business data.

Hotline	
Cyber Insurance Provider	Notify provider within 24 hours of a Critical incident as per policy terms.

Task 5: Security Awareness Training Outline

This Security Awareness Training Plan has been developed for all 25 employees of Ubuntu Innovations (Pty) Ltd. The goal is to build a security-conscious culture by equipping staff with the knowledge and habits needed to prevent, detect, and respond to common cyber threats in their day-to-day work.

5.1 Training Objectives

By the end of the training programme, all employees will be able to:

- 1. Recognise phishing emails, smishing (SMS phishing), and social engineering attempts.
- 2. Create and manage strong, unique passwords using Bitwarden.
- 3. Understand why Multi-Factor Authentication (MFA) is mandatory for all accounts.
- 4. Follow Ubuntu Innovations' Acceptable Use Policy for company devices and systems.
- 5. Report suspicious activity and security incidents promptly and correctly.
- 6. Apply safe browsing and email hygiene habits to reduce the risk of malware infection.

5.2 Target Audience and Delivery

All Staff (25 users)	Foundational security awareness modules – compulsory for everyone.
Finance Department	Additional module on financial fraud, invoice scams, and secure data handling.
Software Development	Additional module on secure coding basics, dependency vulnerabilities, and Git security.
Executive Management	Additional module on Business Email Compromise (BEC) and leadership responsibilities in security culture.
Delivery Format	In-person workshop (1 day) + self-paced online modules (via Google Classroom or LMS). Annual refresher training thereafter.
Duration	Initial training: 1 full day (6 hours). Online refresher modules: 30–60 minutes per module.

5.3 Training Modules

Module	Topics Covered	Duration	Delivery Method
Module 1	Introduction to Cybersecurity – Why It Matters • What is cybersecurity and why it is everyone's responsibility • Overview of current threat landscape in South Africa • Real-world consequences of security breaches • Ubuntu Innovations' security policies at a glance	45 min	Presentation + Group Discussion
Module 2	Phishing, Smishing & Social Engineering • How to identify phishing emails and malicious links • Red flags	60 min	Interactive Workshop + Simulated Phishing Exercise

Module	Topics Covered	Duration	Delivery Method
	in email: spoofed addresses, urgency, attachments • SMS and WhatsApp scam awareness • Pretexting and impersonation attacks • What to do if you click a suspicious link		
Module 3	Password Security & Bitwarden • Why weak passwords are dangerous • Password complexity requirements (min. 12 characters, upper/lower/numbers/symbols) • Using Bitwarden password manager – live demonstration • Never share passwords or write them down • Understanding passphrase-based passwords	45 min	Hands-on Lab (Bitwarden setup)
Module 4	Multi-Factor Authentication (MFA) • What is MFA and how it works • Setting up Google Authenticator / SMS MFA on Google Workspace • MFA on all company accounts is mandatory • Responding to unexpected MFA prompts (MFA fatigue attacks)	30 min	Hands-on Lab (MFA setup)
Module 5	Safe Device & Email Use • Acceptable Use Policy for company devices • No personal software installation without IT approval • Locking screens when stepping away (Win+L / Super+L) • Safe email practices: attachments, links, forwarding • Reporting malware symptoms immediately	45 min	Presentation + Policy Review
Module 6	Data Handling & Privacy • Classification of company data (Public / Internal / Confidential) • Using only approved cloud storage (Google Drive) • POPIA (Protection of Personal Information Act) awareness • Secure disposal of documents and devices	30 min	Presentation + Case Study
Module 7	Incident Reporting & Response (Staff Role) • What counts as a security incident • How to report an incident to the IT Administrator • What NOT to do during an incident (do not reboot, delete files, or self-remediate) • The Incident Response Plan – staff obligations	45 min	Tabletop Exercise
Module 8	Remote Work & VPN Security • Using OpenVPN / WireGuard for secure remote access • Risks of public Wi-Fi and how to stay safe • Keeping home routers updated • Separation of personal and work devices	30 min	Presentation + Q&A

5.4 Department-Specific Additional Modules

Department	Additional Module Topics	Duration
Finance	Invoice fraud & Business Email Compromise (BEC); verifying payment requests via secondary channel; secure handling of payroll and banking data; SARS compliance and data protection.	45 min
Software Development	Secure coding fundamentals; dependency and package vulnerabilities (npm/pip audit); Git repository security (no secrets in commits); API key and credential management; Docker security basics.	60 min
Executive Management	CEO/CFO fraud awareness; BEC and wire transfer scam scenarios; leadership responsibilities in cultivating a security culture; legal and reputational consequences of data breaches under POPIA.	45 min

5.5 Assessment and Completion Criteria

All employees must achieve the following to be marked as compliant:

- Attend or complete all compulsory modules (Modules 1–8).
- Pass the post-training quiz with a minimum score of 80%.
- Complete the simulated phishing exercise (Module 2) and respond correctly.
- Set up Bitwarden and MFA on their company Google Workspace account (verified by IT Admin).

Employees who do not pass the quiz on the first attempt will be required to review the relevant modules and re-sit within five business days. Non-compliance will be escalated to the relevant Department Head.

5.6 Training Schedule and Ongoing Awareness

Initial Training Day	All 25 employees – full-day in-person workshop covering Modules 1–8. Scheduled within the first week of office setup.
New Employee Onboarding	All new hires must complete the full training programme within their first five working days.
Annual Refresher	All staff complete a 60-minute refresher course annually to cover new threats and policy updates.
Quarterly Phishing Tests	IT Administrator sends simulated phishing emails quarterly to test awareness. Results reviewed in the security report.
Security Newsletter	Monthly one-page security tip email distributed to all staff via Google Workspace by the IT Administrator.
Policy Acknowledgement	All staff sign an Acceptable Use Policy acknowledgement form annually. Stored on file by HR.

5.7 Success Metrics

The effectiveness of the Security Awareness Training programme will be measured by:

- Training completion rate: target 100% of all staff within 30 days of launch.
- Phishing simulation click rate: target reduction to below 5% within 12 months.
- Incident report rate: an increase in staff-reported incidents indicates growing awareness.
- Quiz pass rate: target minimum 90% of staff pass on first attempt after 6 months.
- Post-training survey score: target average satisfaction of 4/5 or above.